HERIOT WATT UNIVERSITY

# Forensic Imaging & Data Analysis

F20FO/F21FO – Digital Forensics

*Dr Ryad Soobhany & Dr Mike Just*

LEADERS IN IDEAS AND SOLUTIONS

# Recap

- Steganography
- Encryption
  - What & Why
- Asymmetric and Symmetric Algorithm
- Cryptanalysis
- Signatures
  - Digital Certificates

# Today

- Incident Response Management
- Forensic Imaging
  – Forensic investigation toolkits
- Forensic Data Analysis
- Processing Evidence
- Hardware & Software Write Blocking

# Learning Outcomes

- To perform forensics imaging and analysis of digital evidence
- Understand and explain incident response stages
- Identify when to use write blockers
- Process digital evidence

# Incident Management

- Security policy to manage security incidents
  - Detect security incidents
  - Perform appropriate response

- Need a plan

- Blue Team

# Blue Team

- Defensive security
- Harden organisation's security
- Monitor for intrusions
- Perform Incident Response (IR)

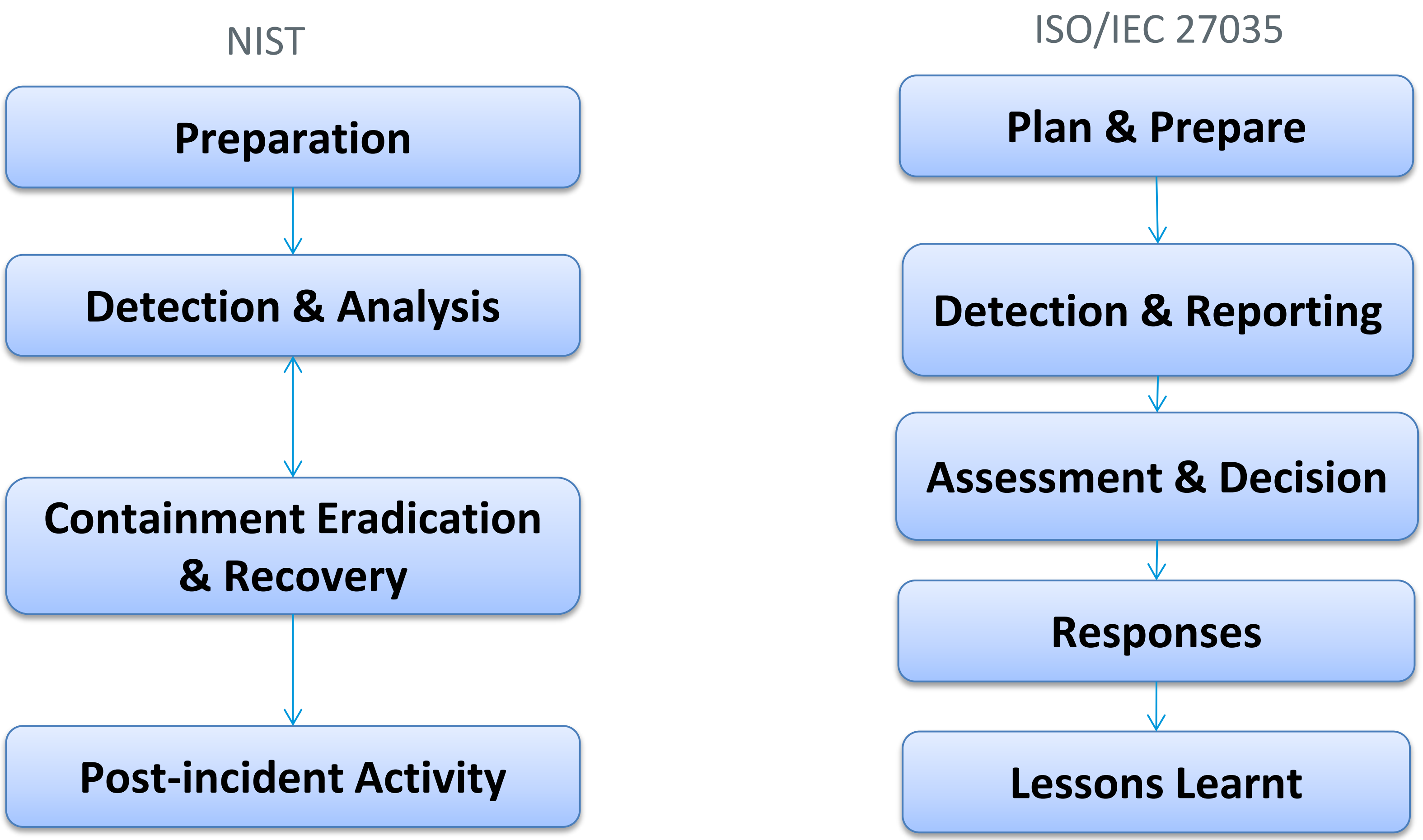
- Prepare and improve IM plan
  - Update security policy after attack

# Blue Team Knowledge

- Digital Forensics
- Vulnerabilities
- Threats
- Forensics and security toolkits

- Good communication skills

# IR Lifecycle



# Preparation

- Preparation is key to success
- Security policies and procedures
- Team well equipped
  - Acquire and train on toolkits
- Apply patches and updates
- Security awareness of staff

# Detection & Analysis

- Digital Forensics related
- Detect incident occurred
  - IOCs
- Analyse collected digital evidence
  - Categorise into benign, suspicious or malicious
  - Need to know what is NORMAL

IOC: Indicators of Compromise

# Containment, Eradication & Recovery

- Isolation
  - Shutdown or disconnect
- Mitigation
  - Reduce severity of infection
- Sandboxing
  - Separate a system from critical resources
- Identify attacking host
- Eradicate threat

# Containment, Eradication & Recovery

- Restore system
- Reinstall apps or OS
- Replace untrusted devices

- Conduct vulnerability scans

# Post-Incident Activities

- Document lessons learned
- Review metrics of incident data
- Evidence retention
  - Prosecution
  - Data retention
  - Cost

# DF and IM

DF and IM:

- Being prepared
- Understanding the concepts
- Mastering the tools
- Knowing what is normal

# Evidence Collection Principles

- Maintain chain of custody for the evidence
- Acquire evidence from volatile as well as non-volatile memory without altering or damaging original evidence
- Maintain the authenticity and reliability of evidence gathered
- No modification of data while analysing it

# Class Task

- Imagine you are asked to go to a crime scene

It is believed that someone has made illegal images (pictures) of a person. You are the first on site and must secure the computer present.

- What should you do?
- How to seize the exhibits?

# Stages of Forensic Incident Response

- Plan
- Identify an issue (Detection)
- Triage
- Data Collection (Acquisition)
- Examination
- Verification
- Reporting

Always follow the guidelines and processes

# Forensics Incident Response Machine OFF

- Secure and take control of the area containing equipment
- Move people away from any computers and power supplies
- Photograph or video the scene and all the components
  - If no camera is  available, sketch the system labelling ports & cables - so can reconstructed later
- Allow any printers to finish printing
- Do not, in any circumstances, switch the device(s) on
- Make sure computer is switched off - screen savers may give the appearance that the computer is switched off, but hard drive and monitor activity lights may  indicate that the machine is switched on
- Be aware that some laptops power on by opening the lid
- Remove the main power source battery from laptops

# Forensics Incident Response Machine OFF

- Unplug the power and other devices from sockets on the computer itself (i.e. not the wall socket)
- A computer that is apparently switched off may be in sleep mode and may be accessed remotely (alteration or deletion of files)
- Label the ports and cables so that the computer may be reconstructed at a later date
- Ensure that all items have signed and completed exhibit labels attached to them
  - Failure to do so may create difficulties with continuity and cause the equipment to be rejected by the forensic examiners
- Search the area for diaries, notebooks or pieces of paper with passwords on which are often attached or close to the computer
- Consider asking the user about the system, including any passwords, if circumstances dictate (record them accurately)
- Make detailed notes of all actions taken

# Forensics Incident Response Machine ON

- Secure the area containing the equipment
- Move people away from computer and power supply
- Photograph or video the scene and all the components
- Consider asking the user about the system, including passwords, if circumstances dictate (record them accurately)
- Record what is on the screen by photographing and by making a written note of the content of the screen
- Do not touch the keyboard or click the mouse
  - If the screen is blank or a screen saver is present, the case officer should be asked to decide if they wish to restore the screen.
  - If so, a short movement of the mouse should restore the screen or reveal that the screen saver is password protected

# Forensics Incident Response Machine ON

- If the screen restores, photograph or video it and note its content
  - If password protection is shown, continue as below, without further touching the mouse
  - Record the time and activity of the use of the mouse in these circumstances
- Where possible, collect data that would be lost by removing the power supply e.g. Running processes and information about the state of network ports at that time
  - Ensure that for actions performed, changes made to the system are understood and recorded
- Consider advice from the owner/user of the computer but make sure this information is treated with caution
- Allow any printers to finish printing

# Forensics Incident Response Machine ON

- If no specialist advice is available, remove the power supply from the back of the computer without closing down any programs
  - When removing the power supply cable, always remove the end attached to the computer and not that attached to the socket
  - This will avoid any data being written to the hard drive if an Uninterruptible power supply (UPS) is fitted
- Remove all other connection cables leading from the computer to other wall or floor sockets or devices
- Bag and Tag everything

# Shutdown or Pull the Plug

- Consider the need for volatile data such as RAM, running processes and network connections
- Large business servers are not fault tolerant for power loss
- Databases should be considered if open connections
- Consider removal of network cable to prevent online data destruction?
- Encryption?

# Evidence Handling in Crime Scene

- Ensure that all items have signed exhibit labels attached to them
- Allow the equipment to cool down before removal
- Search area for diaries, notebooks or pieces of paper with passwords  on which are often attached or close to the computer
- Ensure that detailed notes of all actions are taken in relation to the  computer equipment

# Documenting Evidence

- Naming convention
- Label everything
- Note serial numbers/unique markings
- Photograph everything
- Document time accurately

# Removal of Equipment

- Bag and seal separately all seized  items
- Consider uplifting peripherals where machines are non-standard
- Always take power supplies of
  - laptop, mobile phone, tablet, personal organiser etc

# Evidence Bags

- To preserve the integrity of the exhibit
- Prevents tampering
- Prevents contamination from foreign objects

# Storage

- Exhibit should be stored within restricted access areas
  - Cabinets
  - Rooms

- Movement of exhibits must be recorded, in and out

# Digital Forensic Imaging

- Because of ACPO Principle 1, always try to make an exact copy of evidence and work on that copy

- Produce a “Digital Forensic Image” or “DFI” of the evidence

# Why Create a Duplicate Image

- A file copy does not recover all data areas of the device for examination
- Working from a duplicate image
  - Preserves the original evidence
  - Prevents inadvertent alteration of original evidence during examination
  - Allows recreation of the duplicate image if necessary
- Digital evidence can be duplicated with no degradation from copy to copy

# Bitstream vs Backups

- Are backups sufficient?
  - Ideally NO!
  - Practically it may be the only method available
- Most operating systems only pay attention to the live file system structure
  - Slack, deleted, etc. are not indexed
- Backups generally do not capture this data and they also modify the timestamps of data, contaminating the timeline

# 2 Types of Forensic Image

- Physical evidence file
- Logical evidence file

# Physical Evidence File

- Captures EVERYTHING
- Ideally get the whole physical disc
- Sometimes capturing the logical volume (e.g. the C: drive) may be necessary

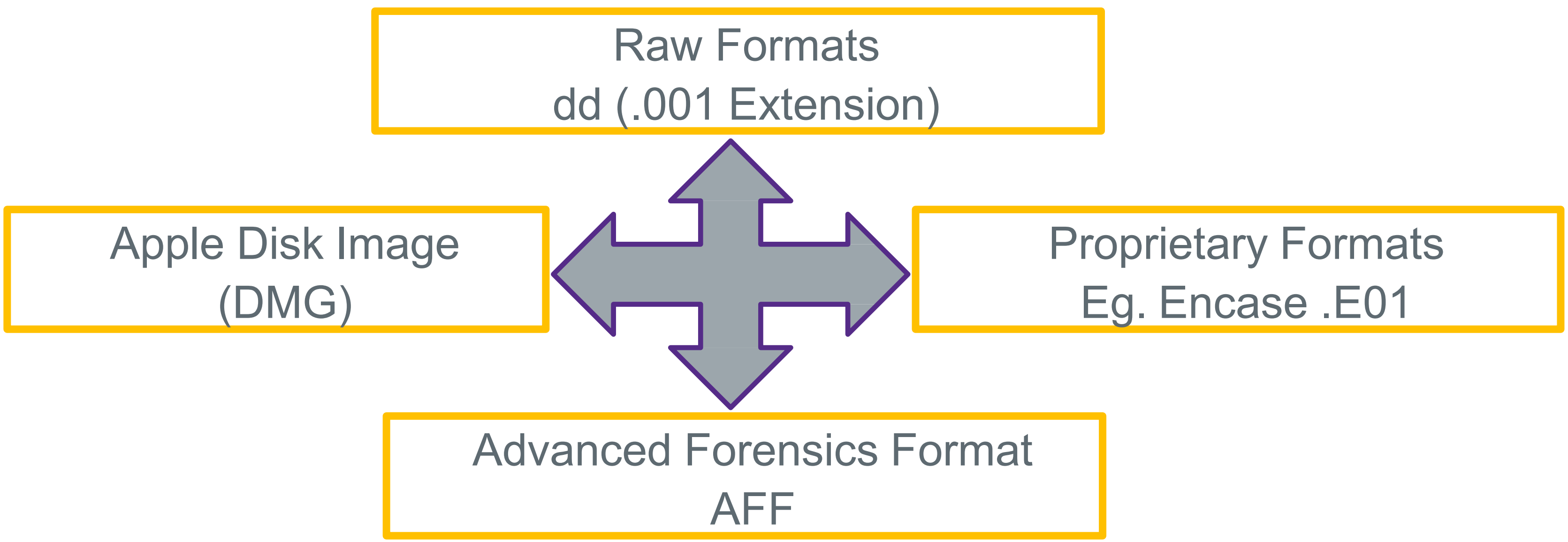
Note: this is still a “physical image” so we get everything on that volume including unallocated clusters!

# Logical Evidence File

- Selective capture of data
- Specific files & folders
- Useful for legal-privilege situations
  - Only capture what is relevant
- Inaccessible data almost always missed with this approach
  - No unallocated clusters

# Storage Format for Evidence

- Raw format
- Proprietary formats



# Raw Format

- This is what the Linux dd command makes
- Bit-by-bit copy of the drive to a file
- Advantages
  - Fast data transfers
  - Can ignore minor data read errors on source drive
  - Most computer forensics tools can read raw format

# Disadvantages of Raw Format

- Requires as much storage as original disk or data
- Tools might not collect marginal (bad) sectors
  - Low threshold of retry reads on weak media spots
  - Commercial tools use more retries than free tools
- Validation check must be stored in a separate file
  - Message Digest 5 ( MD5)
  - Secure Hash Algorithm ( SHA-1 or newer)
  - Cyclic Redundancy Check ( CRC-32)
- Necessary to “zero wipe” destination drives before every use

# Features of Proprietary Formats

- Option to compress or not compress image files
- Can split an image into smaller segmented files
  - Such as to CDs or DVDs
  - With data integrity checks in each segment
- Can integrate metadata into the image file
  - Hash data
  - Date & time of acquisition
  - Investigator name, case name, comments, etc.

# Disadvantages of Proprietary Formats

- Inability to share an image between different tools
- File size limitation for each segmented volume
  - Typical segmented file size is 650 MB or 2 GB
- Expert Witness format is the unofficial standard
  - Used by EnCase, FTK, X-Ways Forensics, and SMART
  - Can produce compressed or uncompressed files
  - File extensions .E01, .E02, .E03, …

# EWF/E01 Formats

- Contains inbuilt error-checking to ensure robustness of captured data
  - Header: contains case info, acquisition info, notes etc.
  - Data blocks: contain blocks of sectors (64 by default,32 KB)
  - CRC check at end of each data block
  - Acquisition hash at end of file
- Supports compression and password protection of DFIs
- Open-source implementation “libewf” published by Joachim Metz

# Logical Evidence Containers

- Logical image formats used to capture selective data
- Common Logical formats:
  - EnCase: LEF aka “L01” file
  - AccessData: “AD1” file
  - X-Ways: Containers (“CTR” files) & “Skeleton” images
- Varying options regarding compression and/or encryption
- These images don’t contain sector level data or inaccessible data

# Note on different Formats

- EWF/E01 is "the standard"
- Raw/DD can be more reliable in acquiring data from damaged/failing discs

- EnCase has also added a new format:
  - Ex01 and Lx01 files
  - "Version 2" of EWF
  - Support for direct encryption (AES) and bzip2 compression

# Making Digital Forensic Images

- Think back to ACPO Principle 1
  - “No action taken by law enforcement agencies, persons employed within those agencies or their agents should change data which may subsequently be relied upon in court”
- When we connect a suspect drive to a forensic workstation to make a DFI, how do we ensure we don’t accidentally alter the suspect drive?

Answer: using a “Write Blocker”

# Write Blockers

- Ideally hardware based, but some software solutions exist
- Write Blocker sits between the forensic workstation and the suspect storage device being imaged
- Prevents the OS from writing to the disk

# How does a Write Blocker work

- A write blocker (hardware or software) works in one of two ways:
  - The tool can either deny all write attempts to the disk and report them to the OS as failures, or
  - The tool caches the writes for the duration of the session and reports them to the OS as successful, but actually prevents the write
- Example of write blocker

  https://www.youtube.com/watch?v=Axx8iGI_gWw

# Software Write Blocker

- A software write block tool operates by monitoring and filtering drive I/O commands sent from an application or OS through a given access interface
- We created a software write blocker in lab02

# Write Blocking Limitations

- Any possible operations that can take place inside of the storage device  that are not accessible or controllable via the interface functionality are outside the scope of write blocking
  – (i.e. Bad sector handling, wear levelling,  SMART-Self-Monitoring Analysis and Reporting Technology, etc.)
  – Write  blocking does not prevent changes to a suspect drive, just prevents our system from changing data on a drive
- No tool or technology is fool-proof or risk proof. Test and know your tools!
- There are times, such as “Live Forensics”, where write blocking of any kind  is not possible
  – In such a case, thoroughly document the steps and tools used and take care to only “touch” what is absolutely necessary

# Summary

- Incident Response Management
- Forensic Imaging
  - Forensic investigation toolkits
- Forensic Data Analysis
- Processing Evidence
- Hardware & Software Write Blocking